NIST SP 800-61 Rev. 3 Incident Response

Released in April 2025

Team Member:

1. Thy Dayuth
2. Mao Sovanrathana
3. Cho Davon
4. Kim Sopanha
5. Kosal Karuna

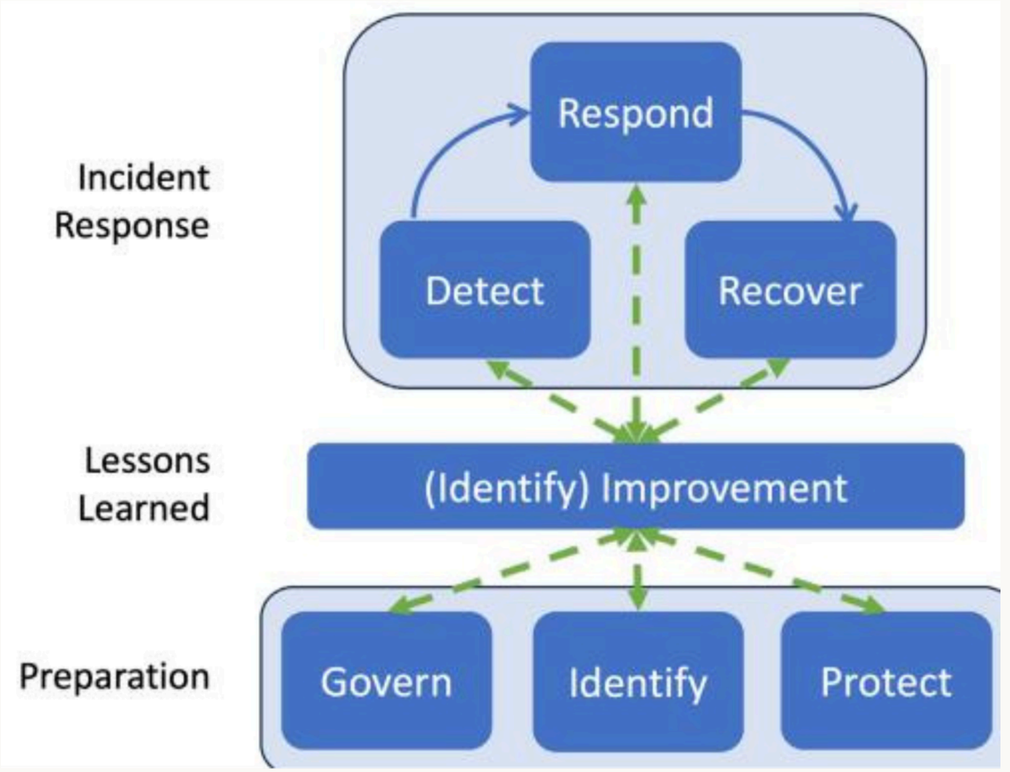
CONTENTS

1. Introduction
2. Evolution from Rev 2 to Rev 3
3. Foundations Incident Response and Community Profile
4. Preparation
5. Detect And Respond
6. Incident Response Reporting and Communication
7. Incident Mitigation
8. Incident Recovery Plan Execution
9. Improvement

1.Introduction

What Is Incident Response?

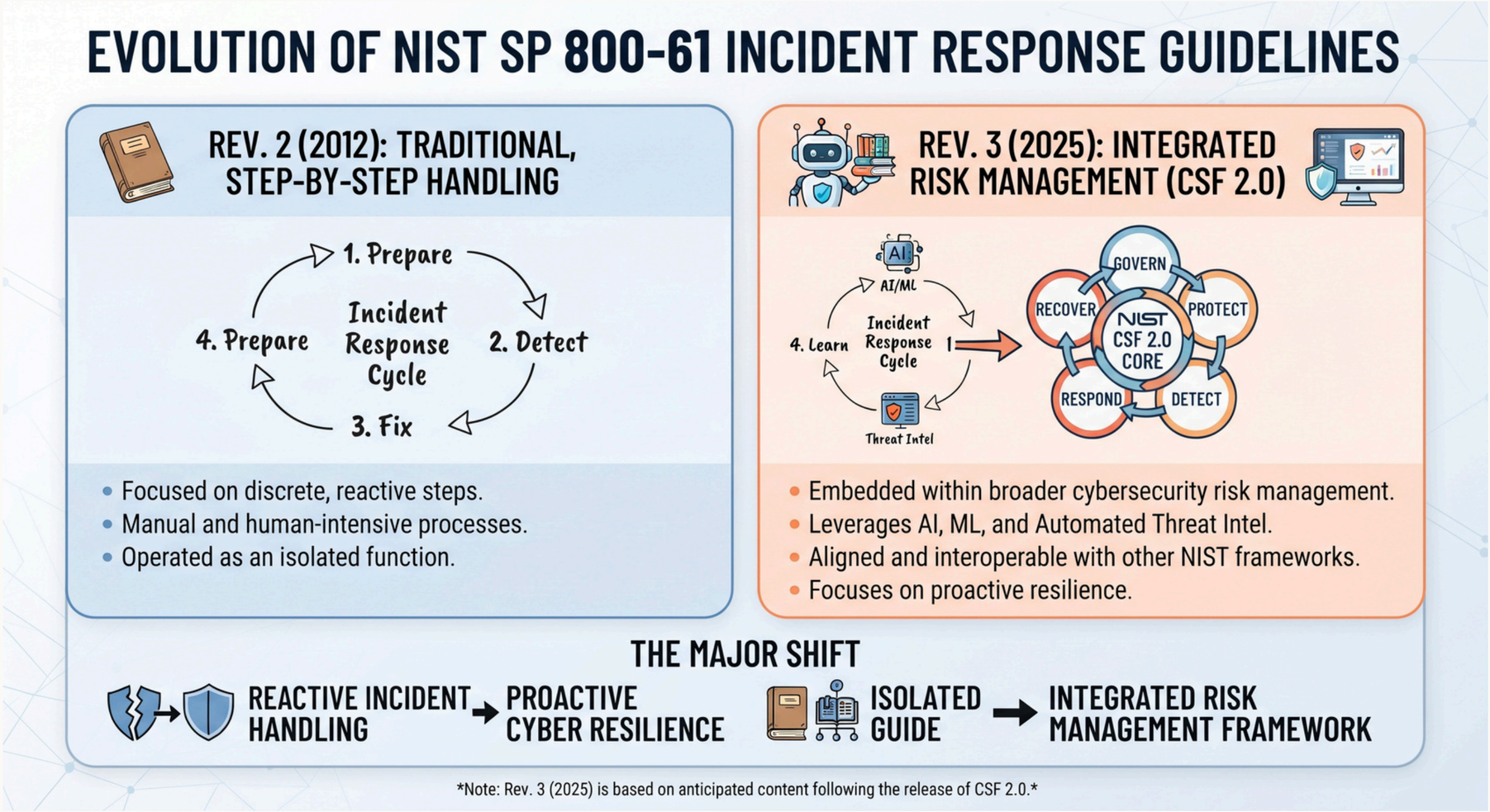
- **Cybersecurity event**: An observable occurrence in a system or network.
- **Adverse event**: An event that may negatively affect an organization's systems, data, or operations.
- **Cybersecurity incident**: An event that compromises, or threatens, the confidentiality, integrity, or availability of information or systems.
- **Purpose**: Detect, manage, contain, and recover from cybersecurity incidents while reducing damage.



Incident response is not just what an organization does after an attack. It is part of everyday cybersecurity risk management.

2.Evolution from Rev 2 to Rev 3

Why Did NIST Update Revision 2 to Revision 3?



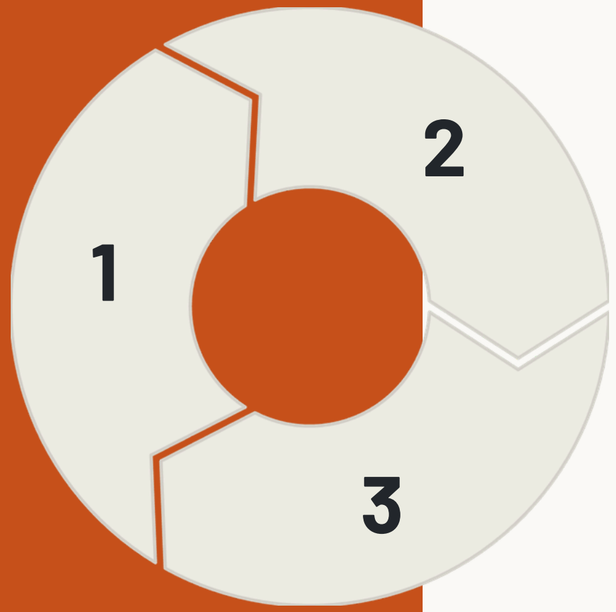
3.Foundations of Incident Response and Community Profile

Roles, Responsibilities, Policy & Playbooks, Community Profile



4. Preparation and Lessons Learned

Govern, Identify, and Protect.



1. Govern
   - IR Policy: Create clear rules for handling security incidents.
   - Legal Requirements: Know when to report incidents to authorities or affected customers.
   - Suppliers: Work with suppliers to manage security incidents.

2. Identify
   - Threat Intelligence: Learn about cyber threats and attack methods.
   - Risk Management: Assess risks and decide how to reduce them.
   - Asset Inventory: Keep a list of important systems, servers, and data.

3. Protect
   - Plans and Exercises: Prepare and test incident response plans.
   - Business Continuity: Keep important services running during incidents.
   - Backups: Back up data and test recovery.
   - Logging: Record system activities to help investigate attacks.

5. Detect: Finding and Declaring an Incident

- **Continuous monitoring (DE.CM):** watch networks, systems, and users for signs of compromise
- **Adverse event analysis (DE.AE):** correlate alerts using SIEM/SOAR and cyber threat intelligence (CTI)
- **Declare an incident (DE.AE-08):** use criteria defined in advance, not guesswork
- **Ransomware example:** unusual mass file encryption and a spike in failed logins trigger alerts



5. Respond: Management and Analysis (Cont)



Management (RS.MA): triage, categorize, and prioritize by risk. Escalate = hand up the chain of authority; elevate = bring in extra expertise. Not first-come, first-served.

Risk factors: asset criticality, functional impact, data impact, and recoverability

Analysis (RS.AN): find the root cause, preserve evidence with chain of custody, and estimate the magnitude (common mistake: underestimating it)

Takeaway: incidents are managed as part of risk management, not as an isolated task

6. Incident Response Reporting and Communication

Communication Type

- Coordination
- Notification
- Public communication
- Information sharing



Set up communication mechanisms in advance

Know what to report, to whom, when and follow notification laws

Share threat information

7. Incident Mitigation

Containment

stop the incident from spreading



Phase 3

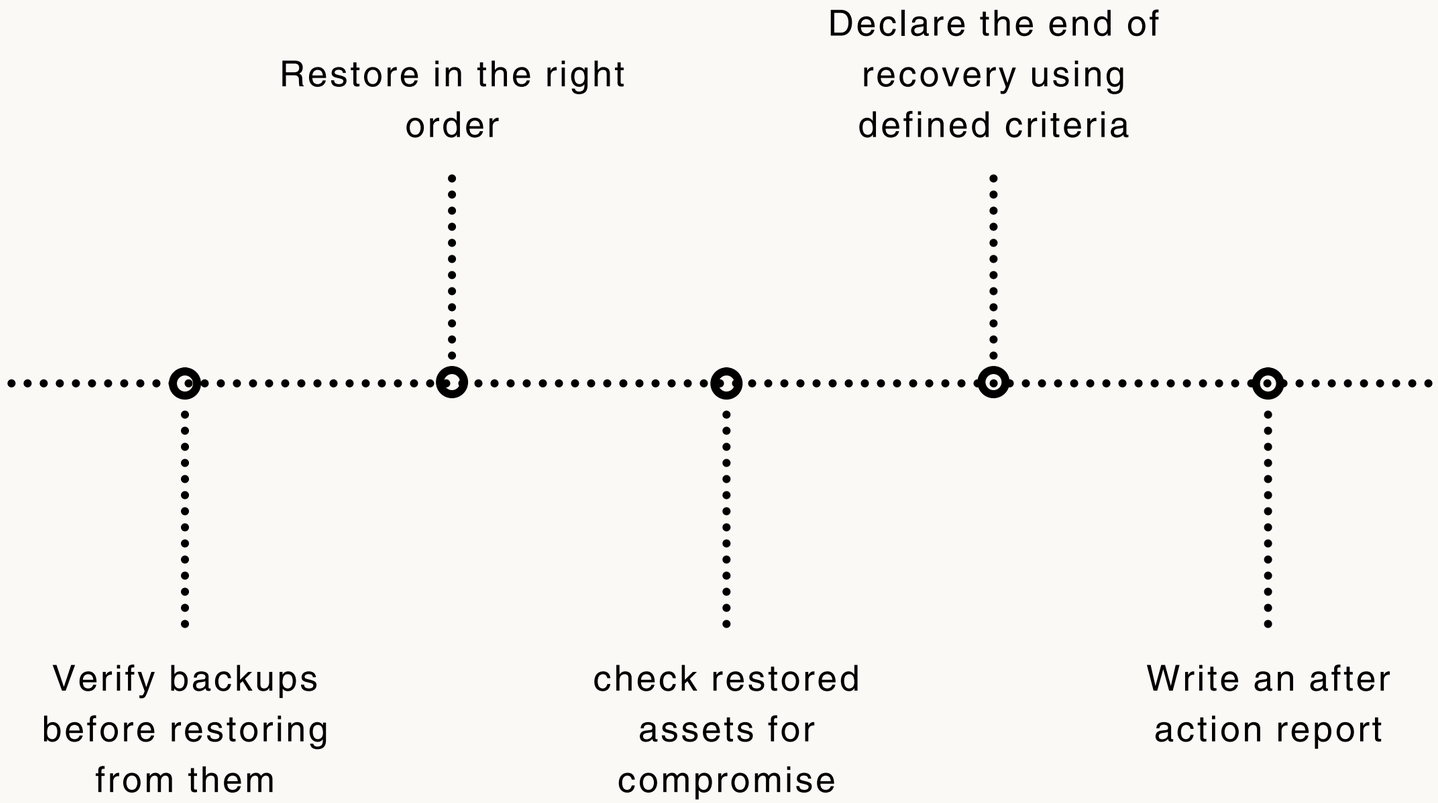
Phase 4



Eradication

remove malware, breached accounts, and entry points

8. Incident Recovery Plan Execution



9. Improvement



Lessons from all six Functions feed into Improvement

Lessons are shared as soon as they are found

Sources :
exercises, evaluations, and real incidents

Result :
better plans, policies, and safeguards



Critical Evaluation & Conclusion

Strengths
- Integrates incident response with CSF 2.0 and risk management
- Emphasizes governance and shared responsibilities
- Supports continuous improvement
- Flexible across different organizations

Limitations
- Less detailed technical how-to guidance than Rev. 2
- Requires additional playbooks and procedures
- Relies on supporting resources and CPRT mappings

Who Should Use It?
Security and incident response teams, IT managers, risk professionals, organizational leadership, and service providers.

THANKS YOU